

WannaCry-Ransomware

Der WannaCry-Ransomware-Angriff im Mai 2017 offenbarte die Anfälligkeit digitaler Infrastrukturen und rasante Verbreitungsgeschwindigkeit von Cyberbedrohungen [BSI17, S.4]. Die Malware nutzte primär die „EternalBlue“-Schwachstelle (MS17-010), ein durch die „Shadow Brokers“-Gruppe geleakte Exploit, der eine Sicherheitslücke im Server Message Block Version 1 (SMBv1)-Protokoll von Microsoft ausnutzte [CISA17; BSI17, S.26]. Diese Schwachstelle ermöglichte WannaCry eine wurmartige Verbreitung innerhalb ungesicherter lokaler Netzwerke und über das Internet auch auf andere anfällige Systeme. Besonders war hierbei, dass dafür keine Benutzerinteraktion mehr erforderlich war [BSI17, S.26]. Nach der Aktivierung auf einem System scannte die Malware das lokale Netzwerk und zufällig ausgewählte IP-Adressen im Internet, um weitere verwundbare Hosts zu finden [CISA17].

Sobald ein System erfolgreich kompromittiert wurde, verschlüsselte WannaCry große Teile des Systems und präsentierte eine Lösegeldforderung. In der Praxis war die Zahlungsfunktion jedoch fehlerhaft, sodass Lösegeldzahlungen vergeblich waren [NAO17, S.16; BSI17, S.26]. Eine weitere Besonderheit des Angriffs war der "Kill Switch": Vor der vollständigen Aktivierung prüfte WannaCry die Erreichbarkeit einer spezifischen, nicht registrierten Domain. Marcus Hutchins registrierte diese und trug damit maßgeblich dazu bei, die Verbreitung der ursprünglichen WannaCry-Variante einzudämmen [CISA17; BSI17, S.26].

Die weltweiten Auswirkungen waren gravierend und betrafen laut Europol über 200.000 Computersysteme in mindestens 150 Ländern [EU17]. Der Wurm unterschied nicht welche Systeme befallen wurden, sodass auch kritische Infrastruktur betroffen war. Beim britischen National Health Service (NHS) waren etwa ein Drittel aller NHS Trusts betroffen, was zur Absage von tausenden Terminen und Operationen führte und die Umleitung von Krankenwagen erforderlich machte [NAO17, S.6, S.19]. Die direkten und indirekten Kosten des Angriffs werden auf mehrere Milliarden geschätzt [NAO17, S.7].

Im Normalfall würde man ein Angreifermodell aufstellen, bevor ein System angegriffen wird, um einen angemessenen Schutzmechanismus aufzustellen. Zur Übungszwecken sollt ihr verkehrt rum nach den Angriffen die Angreifer analysieren und folgende Fragen beantworten:

- Welche grundlegende Schutzziele wurden verletzt und warum?
- Welche Rolle hatten die Angreifer?
- Wie konnten sich die Angreifer verbreiten?
- Welches Verhalten hatten die Angreifer?
- Welche Recourcen und Kompetenzen hatten die Angreifer?
- Welche Motivation hatten die Angreifer?